

Аналитический Отчет по Безопасности 4 Ключевых Экосистем

Сравнительный анализ уязвимостей Go, npm, PyPI и OSS-Fuzz по
ключевым метрикам на базе Google OSV Schema

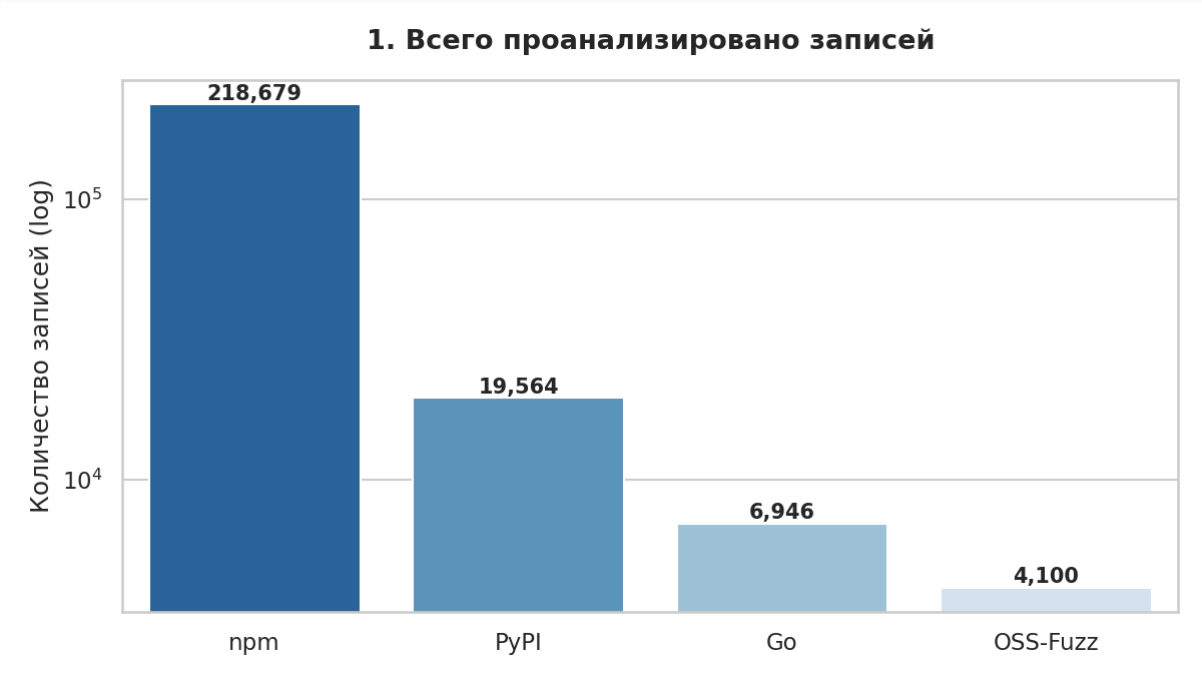
Проектный слой: Исследование данных и скоринг рисков / AI360

Объекты анализа: Go, npm, PyPI, OSS-Fuzz

Контрольная точка: Промежуточная защита (Mid-Review)

Формат документа: 9 страниц графиков + титульный лист

Метрика 1: 1. Всего проанализировано записей

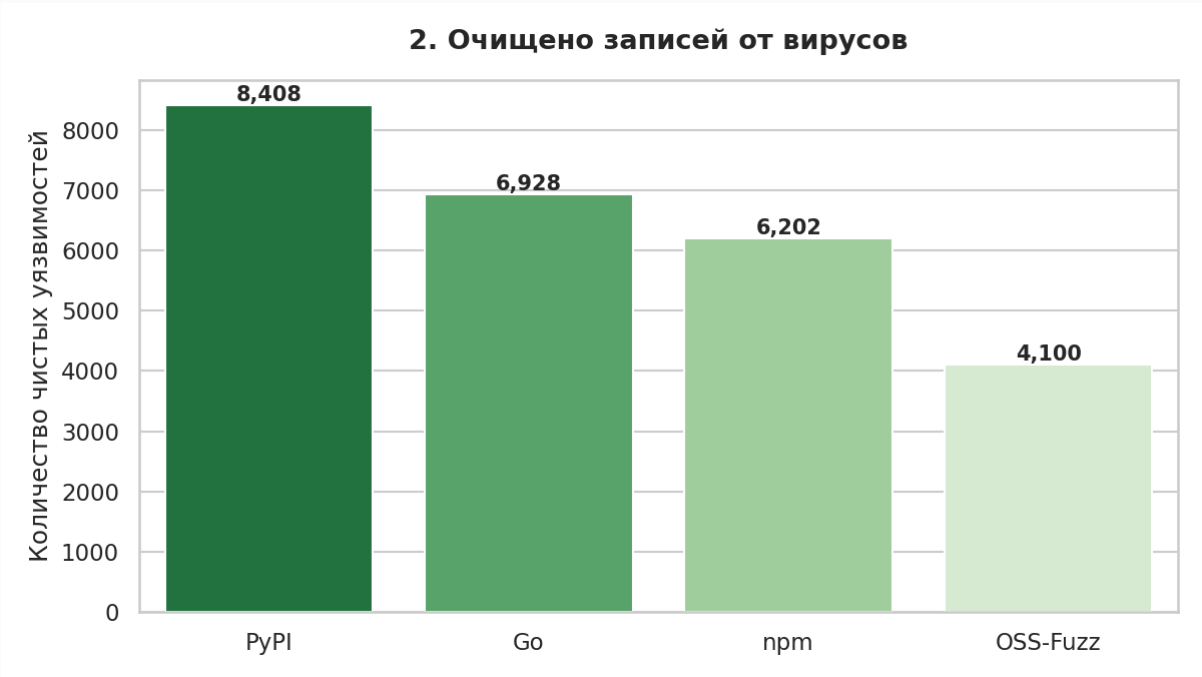


Методологическое значение признака:

Общий объем сырых записей, извлеченных из репозитория Google OSV. Демонстрирует колоссальный масштаб базы npm по сравнению с другими экосистемами (применен логарифмический масштаб).

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*

Метрика 2: 2. Очищено записей от вирусов

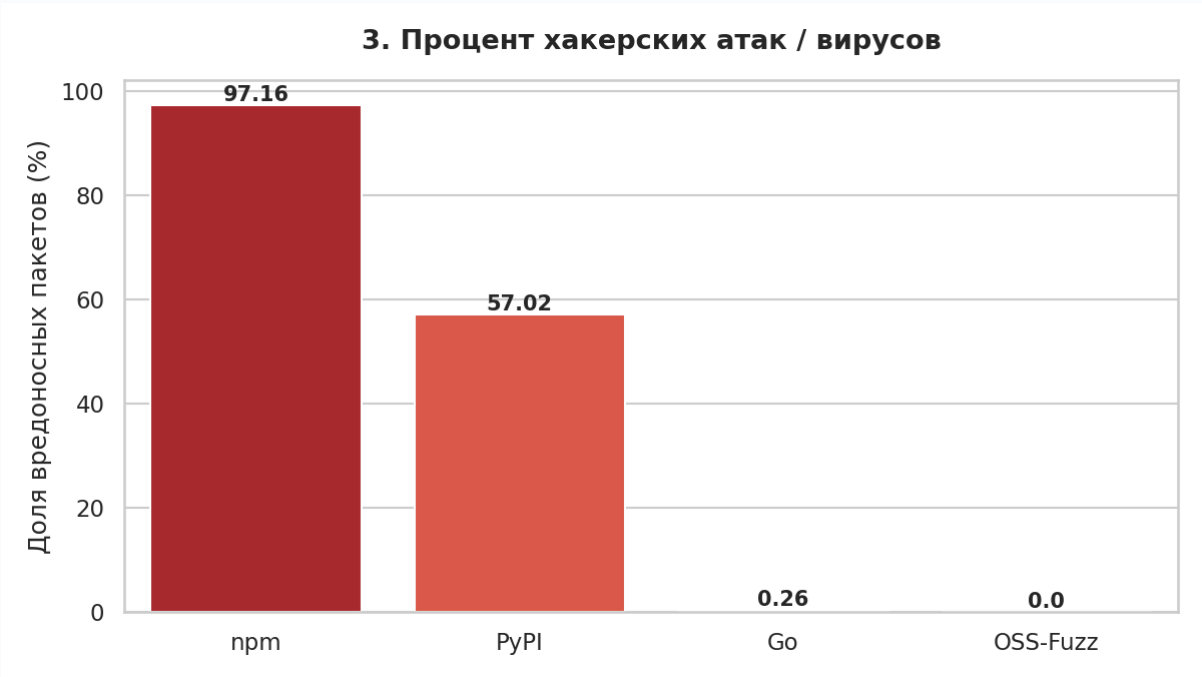


Методологическое значение признака:

Количество записей, прошедших валидацию после исключения умышленно созданного хакерами вредоносного ПО (пакеты типа MAL-). Показывает реальное число классических ошибок в коде.

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*

Метрика 3: 3. Процент хакерских атак / вирусов

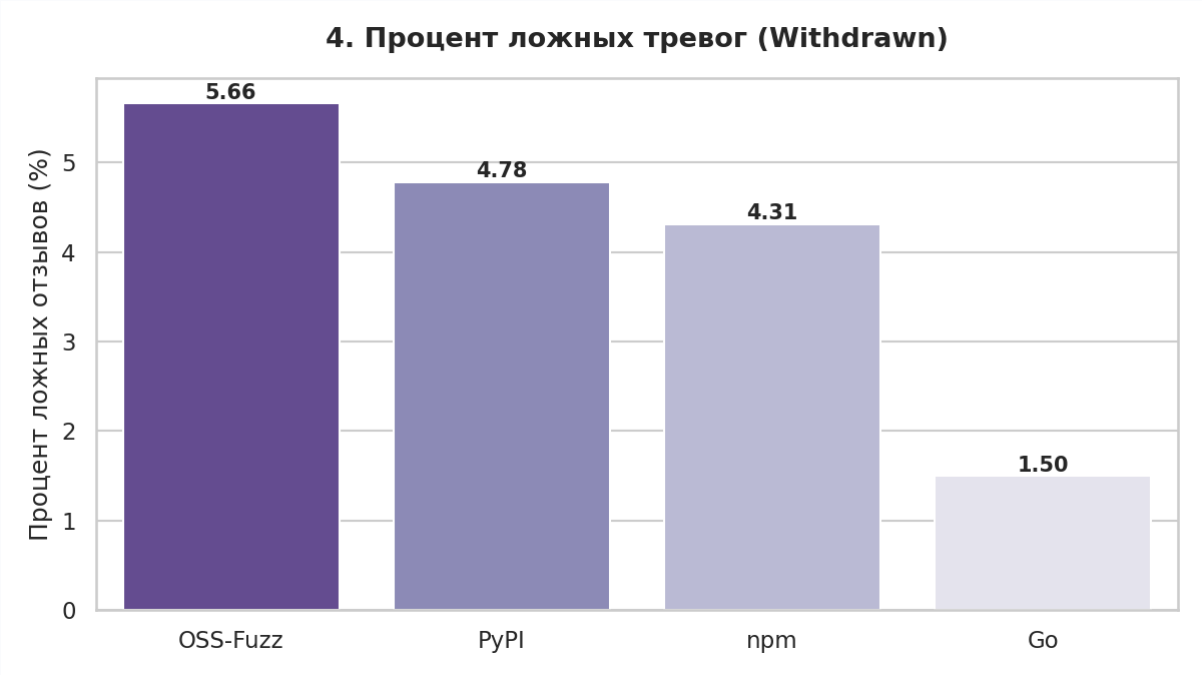


Методологическое значение признака:

Доля пакетов (ID 'MAL-'), внедренных злоумышленниками под видом легитимных библиотек (трояны, стиллеры). Критическая аномалия npm — 97.16% базы состоит из вирусов.

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*

Метрика 4: 4. Процент ложных тревог (Withdrawn)

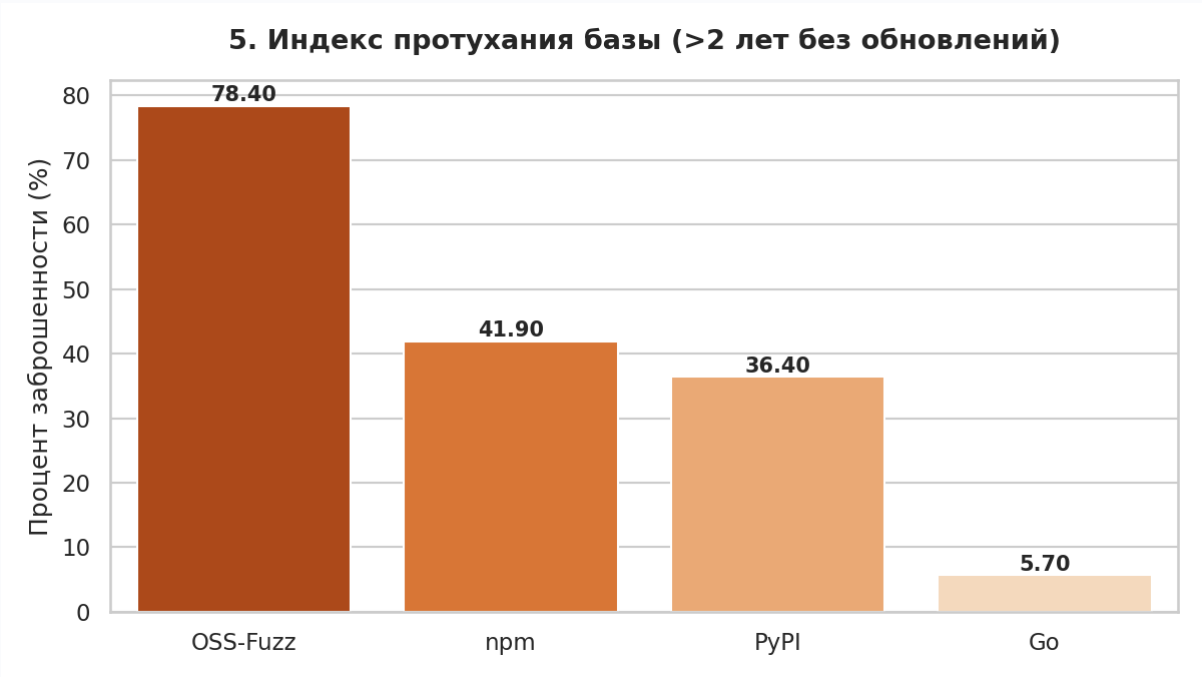


Методологическое значение признака:

Процент уязвимостей, которые были ошибочно занесены в реестр, но затем отозваны модераторами со статусом 'withdrawn'. Свидетельствует о качестве первичной модерации.

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*

Метрика 5: 5. Индекс протухания базы (>2 лет без обновлений)

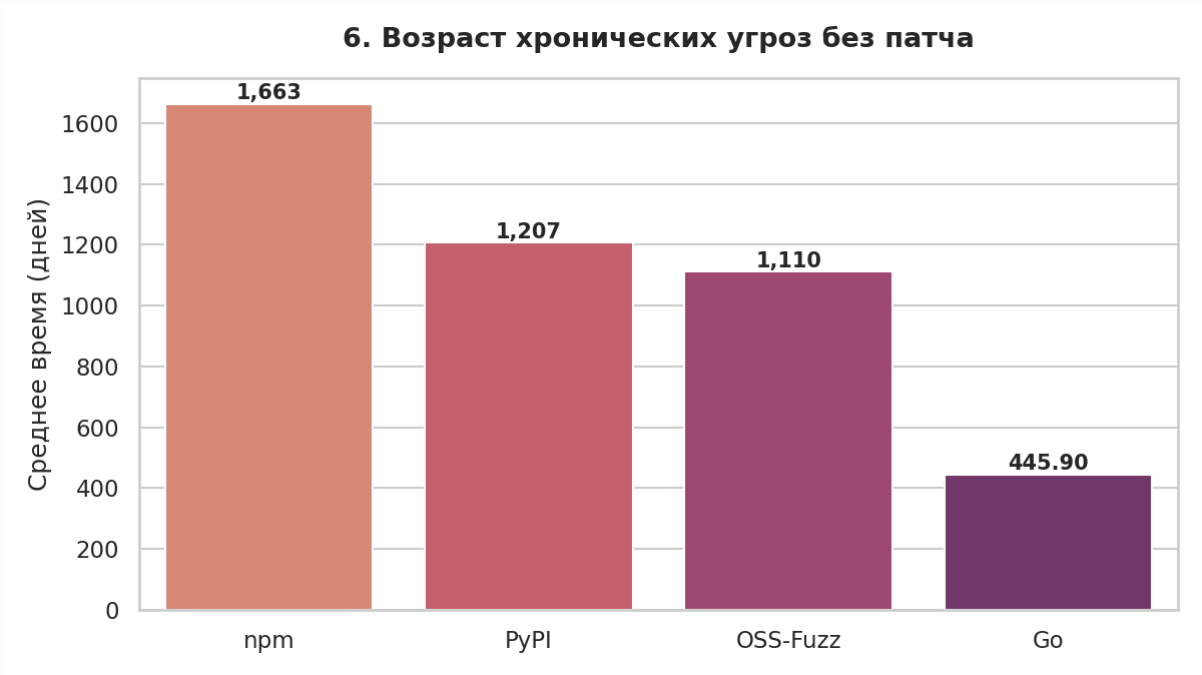


Методологическое значение признака:

Процент легитимных карточек уязвимостей, которые никак не обновлялись или не редактировались аналитиками более двух лет. Маркер 'устаревания' базы данных.

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*

Метрика 6: 6. Возраст хронических угроз без патча

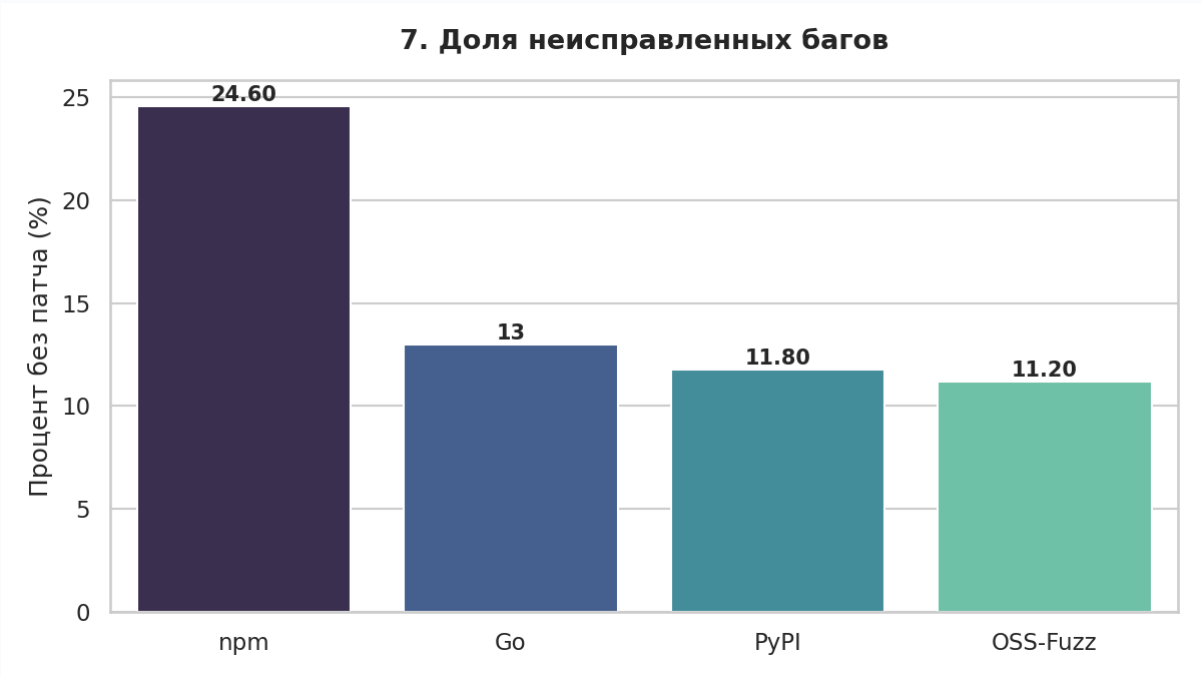


Методологическое значение признака:

Среднее время жизни (в днях) уязвимостей, находящихся в открытом состоянии без официального исправления от авторов. Самый длительный срок исправления зафиксирован у npm.

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*

Метрика 7: 7. Доля неисправленных багов

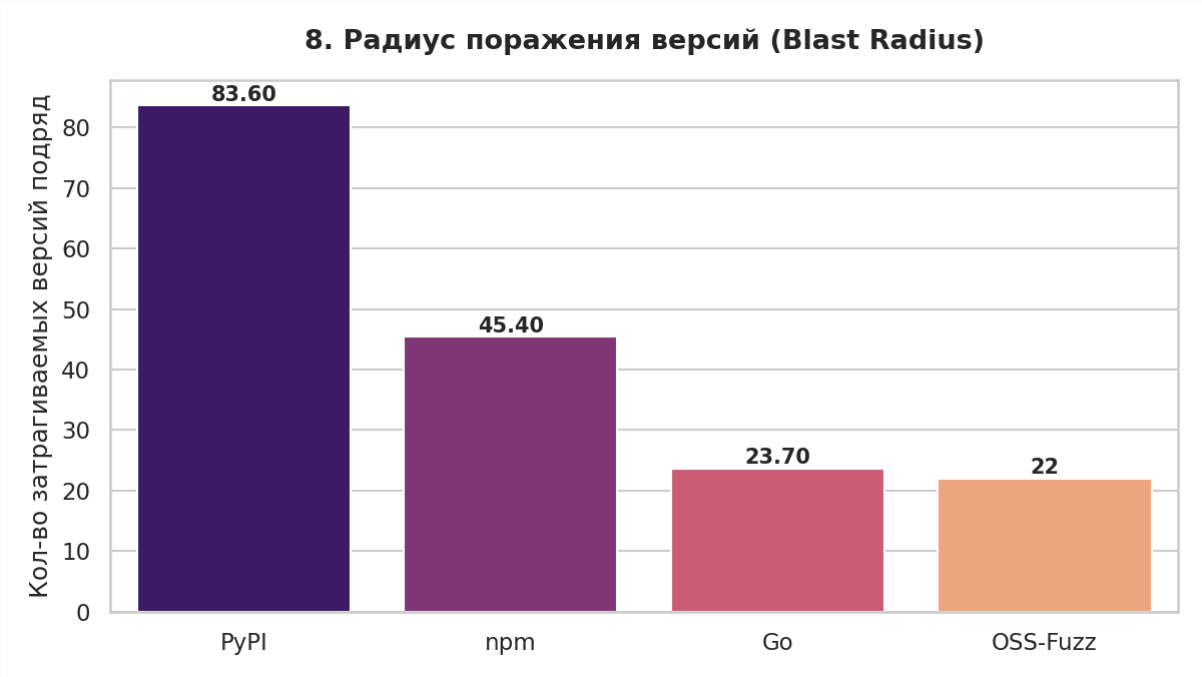


Методологическое значение признака:

Процент легитимных уязвимостей, для которых на текущий момент отсутствует защищенная версия пакета. npm лидирует с четвертью незакрытых брешей.

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*

Метрика 8: 8. Радиус поражения версий (Blast Radius)

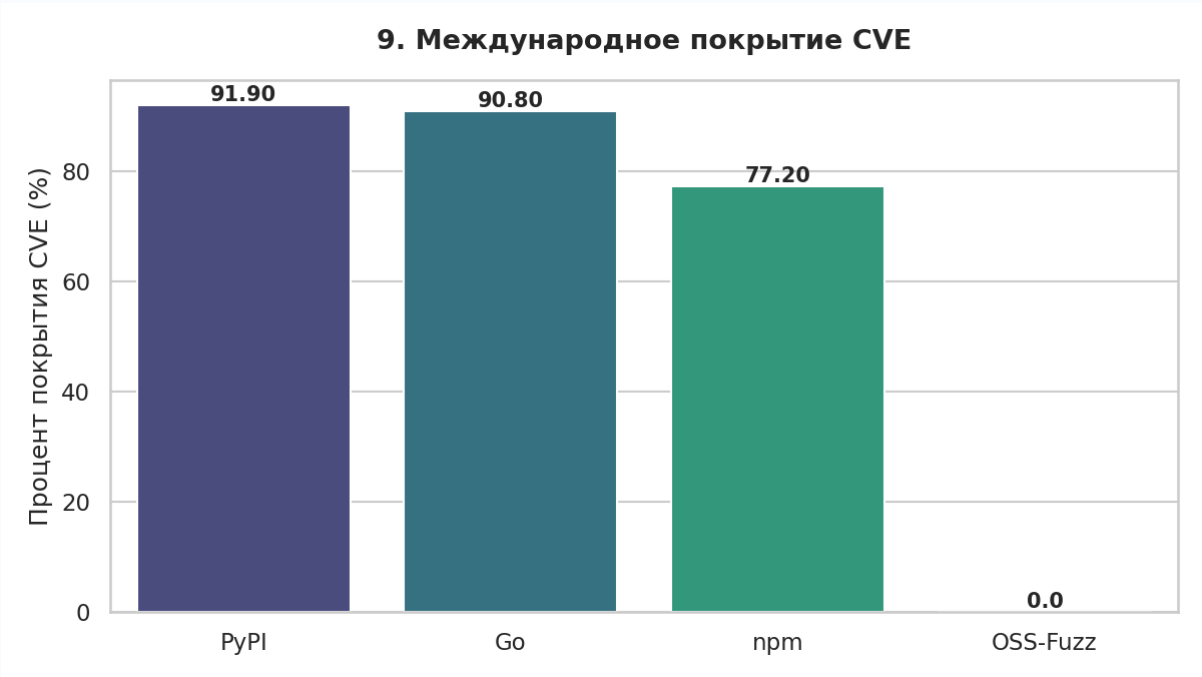


Методологическое значение признака:

Среднее количество последовательных версий одного пакета, которые одновременно компрометируются одной уязвимостью. У PyPI данный показатель максимален (83.6 версий).

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*

Метрика 9: 9. Международное покрытие CVE



Методологическое значение признака:

Процент уязвимостей экосистемы, синхронизированных с глобальной базой CVE. У OSS-Fuzz интеграция отсутствует, тогда как PyPI и Go интегрированы более чем на 90%.

** Аналитический вывод сформирован автоматически на основе выгрузки схем уязвимостей OSV. Сортировка экосистем по убыванию отражает вектор наибольшего риска.*